SECURITY VULNERABILITY REMEDIATION

BEFORE & AFTER COMPARISON REPORT

INFOTACT Week 4 — Final Submission | March 3, 2026

SCAN DETAILS	
Target Host	192.168.91.136 (Ubuntu Linux)
Initial Scan Date	Mon Mar 2, 2026 — Task: INFOTACT AUTHORIZED SCAN
Remediation Scan Date	Tue Mar 3, 2026 — Task: INFOTACT WEEK-4 AFTER REMEDIATION SCAN
Scan Tools	OpenVAS (GVM) + Nmap 7.98 + CIS Benchmark Assessment
Scope	All TCP/UDP ports, authenticated + unauthenticated vulnerability detection
Minimum QoD Filter	70% (OpenVAS)

1. EXECUTIVE SUMMARY

This report presents a complete before-and-after comparison of vulnerability findings on host 192.168.91.136 following a structured remediation cycle. The initial authorized scan (March 2) identified 12 confirmed findings across the High, Medium, and Low severity categories. Targeted remediation actions were applied between March 2 and March 3, after which a verification scan confirmed significant risk reduction.

The post-remediation scan shows a reduction from 12 to 2 findings, representing an overall remediation success rate of 83%. All High-severity and Low-severity findings have been fully resolved. Two Medium findings persist and require follow-up action.

2. REMEDIATION SCORECARD

Metric	Before Remediation	After Remediation	Change
Critical Findings	0	0	—
High Findings	2	0	−2 (100% resolved)
Medium Findings	7	2	−5 (71% resolved)
Low Findings	3	0	−3 (100% resolved)
Total Findings	12	2	−10 (83% resolved)
Open Ports (192.168.91.136)	13	12	−1 (Telnet closed)

3. OPENVAS FINDING COMPARISON

The table below maps every finding from the initial authorized scan to its status in the post-remediation scan. Findings are grouped by original severity level.

3.1 HIGH SEVERITY FINDINGS

Vulnerability	Port	CVSS	Before	After	Status
SNMP Default Community Names	161/udp	7.6	✓ Found	✗ Resolved	✗ RESOLVED
FTP Default Credentials (admin:admin)	21/tcp	7.5	✓ Found	✗ Resolved	✗ RESOLVED

3.2 MEDIUM SEVERITY FINDINGS

Vulnerability	Port	CVSS	Before	After	Status
Telnet Unencrypted Login	23/tcp	4.8	✓ Found	✗ Resolved	✗ RESOLVED
FTP Unencrypted Cleartext Login	21/tcp	4.8	✓ Found	⚠ Persists	⚠ PERSISTS
HTTP TRACE/TRACK Methods Enabled	80/tcp	5.8	✓ Found	⚠ Persists	⚠ PERSISTS
phpinfo() Exposure	80/tcp	5.3	✓ Found	✗ Resolved	✗ RESOLVED
Weak SSH Encryption Algorithms (CBC)	22/tcp	4.3	✓ Found	✗ Resolved	✗ RESOLVED
SSL/TLS Renegotiation DoS	3306/tcp	5.0	✓ Found	✗ Resolved	✗ RESOLVED
Deprecated TLSv1.0/1.1 Protocol	3306/tcp	4.3	✓ Found	✗ Resolved	✗ RESOLVED

3.3 LOW SEVERITY FINDINGS

Vulnerability	Port	CVSS	Before	After	Status
TCP Timestamps Information Disclosure	general/tcp	2.6	✓ Found	✗ Resolved	✗ RESOLVED
Weak SSH MAC Algorithm (hmac-md5)	22/tcp	2.6	✓ Found	✗ Resolved	✗ RESOLVED
ICMP Timestamp Reply Disclosure	general/icmp	2.1	✓ Found	✗ Resolved	✗ RESOLVED

4. NMAP PORT & SERVICE COMPARISON

The Nmap scan targeted all TCP and UDP ports with service version detection and vuln scripts. The table below compares open ports and notable changes between the two scans for host 192.168.91.136.

Port	Service	Version	Before Scan	After Scan	Change / Notes
21/tcp	FTP	ProFTPD 1.3.5e	Open	Open	⚠ Persists (weak config)
22/tcp	SSH	OpenSSH 7.6p1	Open	Open	✓ Config hardened
23/tcp	Telnet	Linux telnetd	Open	Closed	✗ Removed
80/tcp	HTTP	Apache 2.4.29	Open	Open	⚠ TRACE still enabled
111/tcp	RPC	rpcbind 2-4	Open	Open	Unchanged
139/tcp	NetBIOS	Samba smbd	Open	Open	Unchanged
445/tcp	SMB	Samba smbd	Open	Open	Unchanged
2049/tcp	NFS	NFS 3-4	Open	Open	Unchanged
3306/tcp	MySQL	MySQL 5.7.42	Open	Open	✓ TLS hardened
35269/tcp	nlockmgr	NFS lock mgr	Open	Open	Unchanged
42135/tcp	mountd	NFS mount	Open	Open	Unchanged
161/udp	SNMP	SNMP Agent	Exposed	Removed/Secured	✗ Resolved

Key Nmap findings: Telnet (port 23) was confirmed closed in the after-remediation scan, eliminating an unencrypted remote access vector. The SNMP agent (161/udp) was also removed/secured, as it no longer responds to the default community strings "public" and "private". The FTP service (21/tcp) running ProFTPD 1.3.5e remains open; while the default admin:admin credential was removed, the service still does not enforce TLS-encrypted login (AUTH TLS), which represents the primary residual risk.

5. RESOLVED FINDINGS — DETAILED ACTIONS

5.1 SNMP Default Community Names (High — 161/udp)

Before: The SNMP agent responded to both "public" and "private" default community strings, allowing any attacker on the network to read full device MIB data (system info, interfaces, processes) or potentially write configuration changes.

After: The SNMP service has been disabled or the community strings changed. The post-remediation scan shows no response to default community strings.

Action Taken: SNMP service disabled (snmpd stopped and removed from startup) or community strings rotated to non-default values.

5.2 FTP Default Credentials — admin:admin (High — 21/tcp)

Before: The FTP service accepted login with the default credential pair admin:admin, allowing any remote attacker full FTP access including potential file upload/download and server compromise via the ProFTPD mod_copy vulnerability (CVE-2015-3306, CVSS 10.0).

After: The default credential has been removed. The after-remediation scan does not detect successful login with admin:admin.

Action Taken: FTP user password changed; the admin account was either removed or assigned a strong unique password.

5.3 Telnet Service (Medium — 23/tcp)

Before: A Telnet service was running, transmitting all login credentials and session data in cleartext. Any network observer could intercept usernames and passwords.

After: Telnet service no longer appears in port scans; port 23/tcp is closed.

Action Taken: Telnet service disabled (telnetd uninstalled or stopped); SSH remains available for secure remote access on port 22/tcp.

5.4 phpinfo() Exposure (Medium — 80/tcp)

Before: The file /info.php was publicly accessible and exposed PHP version, server OS, configuration paths, and environment variables — providing a reconnaissance goldmine for attackers.

After: The phpinfo() file has been removed. The after-remediation scan no longer detects this endpoint.

Action Taken: /var/www/html/info.php deleted from the web root.

5.5 Weak SSH Encryption Algorithms (Medium — 22/tcp)

Before: SSH accepted CBC-mode ciphers (3des-cbc, aes128-cbc, aes256-cbc) which are susceptible to BEAST-class plaintext recovery attacks.

After: Post-remediation scan shows this finding is no longer triggered.

Action Taken: SSH configuration updated in /etc/ssh/sshd_config to allow only CTR/GCM mode ciphers; CBC-mode algorithms removed.

5.6 SSL/TLS Renegotiation DoS + Deprecated TLS Protocols (Medium — 3306/tcp)

Before: MySQL's SSL/TLS layer supported TLSv1.0, TLSv1.1, and unlimited client-initiated renegotiation, enabling potential DoS via CPU exhaustion.

After: These findings are no longer present in the post-remediation scan.

Action Taken: MySQL SSL configuration updated to restrict to TLSv1.2+ only, with renegotiation limits applied.

5.7 Low Severity Findings (TCP Timestamps, Weak SSH MAC, ICMP Timestamps)

Before: TCP timestamp disclosure, hmac-md5 SSH MAC algorithm support, and ICMP timestamp replies were all detected.

After: None of these findings appear in the post-remediation scan.

Action Taken: net.ipv4.tcp_timestamps=0 applied in /etc/sysctl.conf; SSH hmac-md5 removed from sshd_config; ICMP timestamp replies blocked via iptables or sysctl.

6. PERSISTENT FINDINGS — REQUIRE FOLLOW-UP

Finding	Port	Severity	CVSS	Risk	Recommended Action
FTP Unencrypted Cleartext Login	21/tcp	Medium	4.8	Credential sniffing possible on FTP sessions	Enable FTPS or enforce AUTH TLS in ProFTPD config
HTTP TRACE/TRACK Methods Enabled	80/tcp	Medium	5.8	Cross-Site Tracing (XST) enables credential theft	Add "TraceEnable Off" to Apache config; reload Apache

6.1 FTP Unencrypted Cleartext Login

Despite the removal of the default admin:admin credential, the ProFTPD service continues to accept logins without requiring the AUTH TLS command. This means all FTP credentials are transmitted in plaintext. An attacker with network access can capture login sessions using a packet capture tool.

Recommended Fix: Add the following to /etc/proftpd/proftpd.conf:

```
<IfModule mod_tls.c>
  TLSEngine on
  TLSRequired on
</IfModule>
```

6.2 HTTP TRACE/TRACK Methods Enabled

The Apache web server on port 80 still responds to HTTP TRACE requests. This enables Cross-Site Tracing (XST) attacks which, when combined with XSS vulnerabilities, can expose session cookies and authentication headers that would normally be protected by the HttpOnly flag.

Recommended Fix: Add "TraceEnable Off" to /etc/apache2/apache2.conf, then run "systemctl reload apache2".

7. CONCLUSION & RISK SUMMARY

REMEDIATION ACHIEVEMENTS

- All 2 High findings resolved (100%)
- 5 of 7 Medium findings resolved (71%)
- All 3 Low findings resolved (100%)
- Telnet service removed completely
- SNMP default community strings eliminated
- **Overall: 83% of findings remediated**

REMAINING RISKS TO ADDRESS

- FTP cleartext login (AUTH TLS not enforced)
- HTTP TRACE method still enabled on port 80
- ProFTPD 1.3.5e outdated (CVE-2015-3306 applies)
- Apache 2.4.29 outdated (multiple high CVEs)
- OpenSSH 7.6p1 outdated (CVE-2023-38408 applies)
- **Consider full OS/package upgrade cycle**

The remediation effort conducted between March 2–3, 2026 has significantly reduced the attack surface of host 192.168.91.136. The elimination of all High-severity findings and the disabling of Telnet represents a strong security improvement. The two remaining Medium findings (FTP cleartext and HTTP TRACE) should be addressed in a follow-up maintenance window. A subsequent verification scan is recommended after applying the remaining fixes.

CIS Benchmark Compliance Assessment

In addition to the OpenVAS vulnerability scan, CIS (Center for Internet Security) Benchmark compliance assessments were performed using OpenSCAP against the CIS Ubuntu 18.04 LTS Benchmark profile. These scans measure adherence to security configuration best practices across system settings, network, file permissions, and SSH configuration.

CIS Scan Metadata

Profile	CIS Ubuntu 18.04 LTS Benchmark	CIS Ubuntu 18.04 LTS Benchmark
Scan Time	2026-03-02 06:54:54	2026-03-03 00:54:32
Scan Tool	OpenSCAP with SCAP Security Guide (SSG)	OpenSCAP with SCAP Security Guide (SSG)
Target Host	ubuntu (192.168.91.136)	ubuntu (192.168.91.136)

CIS Compliance Scorecard

Rules Passed	22	**43**	**+21**
Rules Failed	**31**	**10**	**-21 (68% reduction)**
Compliance Score	**1.7%**	**80.4%**	**+78.7 pts**
High Severity Failures	**1**	**0**	**100% resolved**
Medium Severity Failures	**16**	**5**	**69% resolved**
Low Severity Failures	14	5	**64% resolved**

CIS Rule Findings: Before vs. After Remediation

Ensure /home Located On Separate Partition	LOW	**FAIL**	**FAIL**	Persistent
Ensure /tmp Located On Separate Partition	LOW	**FAIL**	**FAIL**	Persistent
Ensure /var Located On Separate Partition	LOW	**FAIL**	**FAIL**	Persistent
Ensure /var/log Located On Separate Partition	LOW	**FAIL**	**FAIL**	Persistent
Ensure /var/log/audit Located On Separate Partition	LOW	**FAIL**	**FAIL**	Persistent
Ensure /var/tmp Located On Separate Partition	**MEDIUM**	**FAIL**	**FAIL**	Persistent
Disable RDS Support	LOW	**FAIL**	**PASS**	Resolved
Disable TIPC Support	LOW	**FAIL**	**PASS**	Resolved
Verify Permissions on passwd File	**MEDIUM**	**FAIL**	**PASS**	Resolved
Verify Permissions on shadow File	**MEDIUM**	**FAIL**	**PASS**	Resolved
Verify that All World-Writable Directories Have Sticky Bits Set	**MEDIUM**	**FAIL**	**PASS**	Resolved

Ensure No World-Writable Files Exist	MEDIUM	FAIL	PASS	Resolved
Disable Mounting of cramfs	LOW	FAIL	PASS	Resolved
Disable Mounting of freevxfs	LOW	FAIL	PASS	Resolved
Disable Mounting of hfs	LOW	FAIL	PASS	Resolved
Disable Mounting of hfsplus	LOW	FAIL	PASS	Resolved
Disable Mounting of jffs2	LOW	FAIL	PASS	Resolved
Disable Mounting of udf	LOW	FAIL	PASS	Resolved
Disable core dump backtraces	MEDIUM	FAIL	FAIL	Persistent
Disable storing core dump	MEDIUM	FAIL	FAIL	Persistent
Enable Randomized Layout of Virtual Address Space	MEDIUM	FAIL	PASS	Resolved
Set SSH Client Alive Count Max to zero	MEDIUM	FAIL	PASS	Resolved
Set SSH Client Alive Interval	MEDIUM	FAIL	PASS	Resolved
Disable Host-Based Authentication	MEDIUM	FAIL	PASS	Resolved
Disable SSH Access via Empty Passwords	HIGH	FAIL	PASS	Resolved
Disable SSH Support for .rhosts Files	MEDIUM	FAIL	PASS	Resolved
Disable SSH Root Login	MEDIUM	FAIL	PASS	Resolved
Do Not Allow SSH Environment Options	MEDIUM	FAIL	PASS	Resolved
Enable SSH Warning Banner	MEDIUM	FAIL	PASS	Resolved
Set LogLevel to INFO	LOW	FAIL	PASS	Resolved
Set SSH authentication attempt limit	MEDIUM	FAIL	PASS	Resolved

Note: The after-remediation scan additionally revealed 2 new failures for Verify Permissions on Backup passwd File and Verify Permissions on Backup shadow File (medium severity), which were exposed after fixing original passwd/shadow permission issues. These require follow-up action.

Report prepared by INFOTACT Security Team | March 3, 2026